

LABORATORY EXERCISE: PROJECT TASK 1

Legal Requirements Register – NorthStream Energy & Logistics

Course: Cybersecurity Legislation and Compliance Assessments

Module: 2 – Canadian Legal Framework (Privacy & Data)

Student: HASSANI Mohammad Salem

Date: January 14, 2026

Instructor: Asen Grozdanov

EXECUTIVE SUMMARY

TO: NorthStream Energy & Logistics Executive Leadership

RE: Multi-Jurisdictional Privacy Compliance Requirements

FROM: Compliance Assessment Team

NorthStream Energy & Logistics operates across four Canadian provinces—Alberta, British Columbia, Ontario, and Quebec—making compliance with Canadian privacy law a critical operational and legal requirement. While the federal Personal Information Protection and Electronic Documents Act (PIPEDA) provides a baseline framework for private sector data handling, it is insufficient as a standalone compliance strategy for your organization.

The central complication is jurisdictional fragmentation. Each province where NorthStream operates applies its own privacy requirements, and Quebec—where your Rewards Cloud infrastructure is housed in Montreal—enforces the newly revised Quebec Law 25, which is materially stricter than PIPEDA. This creates a "compliance gap" if your organization attempts to apply federal standards universally.

The most acute risk stems from your NorthStream Rewards mobile application and the Montreal-based cloud infrastructure. The app collects sensitive location data (GPS coordinates), consumer purchasing habits, and partial financial information—all classified as Restricted Personal Information under Canadian privacy frameworks. Quebec Law 25 mandates explicit consent mechanisms, mandatory privacy impact assessments, and appointment of a Privacy Officer for organizations processing this data. Non-compliance carries penalties up to 100,000 CAD per violation in Quebec, compared to PIPEDA's 15,000 CAD maximum.

Recommendation: Adopt Quebec Law 25 as your organization-wide baseline for all Canadian operations. While this appears more burdensome than PIPEDA, it ensures that all customer, employee, and marketing data meets the highest Canadian privacy standard, eliminates jurisdictional audit risk, and positions NorthStream for future compliance with even stricter frameworks (e.g., Canadian GDPR equivalents under development).

PART 1: DATA CLASSIFICATION

Classification Framework

NorthStream's data assets are classified according to the following sensitivity tiers:

- **PUBLIC:** Information intended for general public release (e.g., press releases, published operational statistics)
- **INTERNAL:** Business data with low privacy/security risk (e.g., meeting notes, cafeteria schedules)
- **CONFIDENTIAL (PII):** Personally Identifiable Information that identifies or could identify an individual (e.g., name, email, phone)
- **RESTRICTED (Sensitive PII/PHI/Financial):** High-risk data including health information, financial records, government ID numbers, biometric data, or precise location history

Data Assets Inventory & Classification

Data Asset	Data Type	Classification	Justification
Employee Records	SIN, home address, banking info, health benefits claims	RESTRICTED	Includes SIN (sensitive identifier), financial/banking data, and health information (PHI)
Rewards App Data	Customer name, email, GPS location history, partial credit card (last 4)	RESTRICTED	GPS location = precise tracking capability; credit card = financial data; combined = high re-identification risk
Pipeline Sensor Data	Real-time pressure, flow measurements (critical infrastructure)	INTERNAL (from privacy perspective)	Not PII; however, operational sensitivity exists for infrastructure protection
Marketing Database	50,000 email addresses, subscription preferences	CONFIDENTIAL	Contact information = PII; managed by third-party US

Data Asset	Data Type	Classification	Justification
			vendor = jurisdictional complexity

PART 2: LEGAL REQUIREMENTS REGISTER

Project Task 1 Deliverable

The following table identifies minimum 5 distinct Canadian legal requirements applicable to NorthStream based on data type, jurisdiction, and processing activity.

LEG-01: REWARDS APP GPS CONSENT

Field	Detail
ID	LEG-01
Data Subject	Rewards App Users (Consumers)
Jurisdiction	Canada-wide (Federal), with enhanced requirements in Quebec
Applicable Legislation	PIPEDA Principle 4.3 (Consent) + Quebec Law 25 Article 13 (Express Consent)
Specific Requirement	EXPLICIT, INFORMED CONSENT must be obtained BEFORE collecting, using, or disclosing GPS location data. Implied consent is insufficient. Consent must be freely given, specific to location services, and clearly distinguish from other app permissions.
NorthStream Context	The NorthStream Rewards app collects real-time GPS coordinates to track driver location and fuel stop history for discount eligibility verification. Under PIPEDA Principle 4.3, consent is a prerequisite. Under Quebec Law 25 Article 13, consent for sensitive data (which includes location) must be express—meaning the

Field	Detail
	customer must actively click "I agree to location tracking" BEFORE the app accesses location services. A privacy policy alone, or pre-checked boxes, is non-compliant.
Compliance Action	Implement an explicit opt-in consent screen at first app launch: "NorthStream Rewards uses your location to offer fuel discounts. Click 'Enable Location' to proceed." Log all consent grants and maintain records. Provide withdrawal mechanism. Conduct privacy impact assessment under Law 25.
Risk Assessment	Non-compliance Penalty: PIPEDA: up to 15,000 CAD; Quebec Law 25: up to 100,000 CAD per violation. Business Impact: Unauthorized location tracking could result in class-action lawsuits, app store removal, and regulatory investigation.

LEG-02: EMPLOYEE SENSITIVE DATA SECURITY (SIN/BANKING/HEALTH)

Field	Detail
ID	LEG-02
Data Subject	Employees (1,200 staff across 4 provinces)
Jurisdiction	Federal (PIPEDA applies to interprovincial operations; additionally, Quebec Law 25 for employees in Quebec; PIPA for BC and Alberta employees)
Applicable Legislation	PIPEDA Principle 4.7 (Safeguards) + Principle 4.2 (Use, Disclosure Limitation) + Quebec Law 25 Articles 14–18 (Security Obligations)
Specific Requirement	Organizations must implement appropriate physical, organizational, and technological safeguards proportionate to the sensitivity of the personal information. For SIN, banking information, and health claims (all "Sensitive PII"),

Field	Detail
	this requires: (a) encryption at rest and in transit; (b) access controls limiting employee data to HR and payroll only; (c) regular security audits; (d) incident response procedures; (e) employee training on data handling. Quebec Law 25 raises the bar further, mandating documented information security policies and breach notification within 24 hours.
NorthStream Context	NorthStream stores employee records—including Social Insurance Numbers (SIN), home addresses, banking details for direct deposit, and health benefits claims—on servers in Calgary, Alberta. Under PIPEDA Principle 4.7, these records must be protected by safeguards appropriate to their sensitivity. SIN is a critical identifier (Sensitive PII); banking information is financial; health claims are health information (PHI). Current storage must employ encryption, role-based access, audit logging, and breach protocols. For employees in Quebec, Law 25 imposes stricter standards: a documented information security program, annual risk assessments, and mandatory Privacy Officer oversight.
Compliance Action	(1) Conduct security audit of Calgary HR servers; (2) Implement AES-256 encryption for stored data; (3) Deploy role-based access control (RBAC)—only HR/Payroll staff access SIN/banking; (4) Establish audit logs for all access; (5) Provide annual data handling training; (6) Document information security policy; (7) Establish 24-hour breach notification procedure; (8) Appoint Privacy Officer (see LEG-04).
Risk Assessment	Non-compliance Penalty: PIPEDA: up to 15,000 CAD (per incident); Quebec Law 25: up to 100,000 CAD. Business Impact: Data breach involving SIN/banking could expose employees to identity theft, trigger regulatory investigation, and result in significant remediation costs. Regulatory enforcement has increased under Law 25.

LEG-03: EMAIL MARKETING & ANTI-SPAM CONSENT (CASL)

Field	Detail
ID	LEG-03
Data Subject	Marketing List Subscribers (50,000 email addresses)
Jurisdiction	Canada-wide
Applicable Legislation	CASL (Canada's Anti-Spam Legislation), Part 1 – Section 6 (Consent Requirement)
Specific Requirement	EXPRESS CONSENT must be obtained BEFORE sending commercial electronic messages (emails, SMS, social media messages) to Canadian recipients. "Implied consent" (e.g., "you purchased before, so we assume you want promotions") is not sufficient under CASL. Consent must be documented, specific, and freely given. Additionally, every commercial message must include: (a) identifiable information about the sender; (b) clear unsubscribe mechanism; (c) honor unsubscribe requests within 10 business days.
NorthStream Context	NorthStream maintains a marketing database of 50,000 email addresses for newsletter distribution, managed by a third-party vendor in the United States. If NorthStream (or its vendor) sends promotional emails to Canadian recipients, CASL applies regardless of where the vendor is located. The law does NOT permit "implied consent" from past fuel purchases. Each recipient must have actively consented (e.g., checked a box, filled a form) to receive promotional emails. A privacy policy or newsletter signup page does not constitute consent without explicit opt-in. Current vendor practices must be audited to confirm CASL compliance. Non-compliant emails can trigger Canadian Radio-television and Telecommunications Commission (CRTC) investigation.
Compliance Action	(1) Audit third-party vendor contract for CASL compliance clauses; (2) Verify that marketing list was built with express, documented consent; (3) Review all promotional email templates for required sender identification and unsubscribe links; (4) Establish unsubscribe processing procedure (ensure honor within 10

Field	Detail
	days); (5) Document consent records (dates, mechanism, recipient confirmation); (6) Implement double-opt-in: initial signup + confirmation email.
Risk Assessment	Non-compliance Penalty: CASL: up to 1,000,000 CAD in fines and 15 million CAD in damages (highest penalty among Canadian privacy laws). Business Impact: Single non-compliant campaign to 50,000 addresses could trigger CRTC complaint, reputational damage, and substantial penalties.

LEG-04: QUEBEC LAW 25 – PRIVACY OFFICER & PRIVACY IMPACT ASSESSMENT

Field	Detail
ID	LEG-04
Data Subject	All Rewards App users residing in Quebec; all Quebec employees
Jurisdiction	Quebec (Provincial)
Applicable Legislation	Quebec Law 25 (Loi modernisant les dispositions législatives en matière de protection des renseignements personnels), Articles 3–8 (Privacy Officer), Articles 25–28 (Privacy Impact Assessments)
Specific Requirement	Organizations collecting personal information from Quebec residents must: (1) Appoint a designated Privacy Officer responsible for compliance oversight, complaint handling, and liaison with the Commission d'accès à l'information du Québec (CAI); (2) Conduct Privacy Impact Assessments (PIAs) before deploying any new data processing system involving Quebec residents' data; (3) Maintain and publish privacy policies in clear, understandable language; (4) Ensure data processing agreements with third-party vendors include Law 25 compliance clauses. Law 25 applies to all organizations processing data of Quebec residents,

Field	Detail
	even if headquartered elsewhere. The law is effective as of 2023 and carries penalties up to 100,000 CAD per violation.
NorthStream Context	NorthStream's Rewards Cloud infrastructure is hosted in Montreal, Quebec. This infrastructure processes Rewards App data for Quebec customers and stores data of Quebec-based employees and contractors. Under Quebec Law 25, NorthStream must: (a) appoint a Privacy Officer (full-time or contracted) to oversee compliance; (b) conduct a Privacy Impact Assessment before the Rewards App operates in Quebec, documenting data flows, legal basis, consent mechanisms, and security measures; (c) register the PIA with the CAI; (d) publish a Quebec-specific privacy policy compliant with Law 25's clarity requirements; (e) include Law 25 clauses in vendor contracts, particularly for the Montreal cloud hosting provider. The vendor hosting the Rewards Cloud in Montreal is itself subject to Law 25 and must sign a data processing agreement. Failure to appoint a Privacy Officer is a standalone violation (up to 100,000 CAD) regardless of other compliance status.
Compliance Action	(1) Immediately appoint Privacy Officer (internal or external consultant—given size, likely external); (2) Commission Privacy Impact Assessment for Rewards App (cost: 5,000–15,000 CAD); (3) File PIA with CAI and obtain approval letter; (4) Draft Quebec-specific privacy policy (distinct from federal PIPEDA policy); (5) Amend Montreal cloud hosting contract to include Law 25 data processing terms; (6) Establish Privacy Officer office procedures (complaint handling, CAI liaison, annual reporting).
Risk Assessment	Non-compliance Penalty: Quebec Law 25: up to 100,000 CAD per violation (multiple violations for missing Privacy Officer, missing PIA, non-compliant vendor contracts). Business Impact: Operating in Quebec without Privacy Officer is per se non-compliant and subjects organization to immediate regulatory enforcement. CAI has published enforcement guidelines prioritizing Privacy Officer appointment.

LEG-05: EMPLOYEE DATA IN FEDERALLY REGULATED INDUSTRIES (FWUB CONSIDERATION)

Field	Detail
ID	LEG-05
Data Subject	Employees across all operations (federal jurisdiction question)
Jurisdiction	Potentially Federal (if NorthStream's interprovincial transportation operations qualify as "Federal Works, Undertakings, or Businesses" under the Canadian Constitution)
Applicable Legislation	PIPEDA Part 2 (applies to federal crown corporations and Canadian-owned companies engaged in interprovincial or international undertakings); Section 4(1) of PIPEDA defines scope; <i>R. v. Kitkatla Band</i> , [2002] 2 S.C.R. 146 (Supreme Court precedent on federal jurisdiction)
Specific Requirement	Jurisdictional determination: If NorthStream's transportation and pipeline operations constitute a "Federal Work, Undertaking, or Business" (FWUB), then all employee data is subject to federal PIPEDA regardless of provincial location. FWUBs include: (a) interprovincial transportation (trucking fleets operating in multiple provinces); (b) interprovincial pipeline infrastructure; (c) telecommunications; (d) banking/financial institutions. If NorthStream qualifies, federal law supersedes provincial law for employee data, simplifying compliance to PIPEDA (not PIPA or Law 25) but requiring strict federal standards. This is a "trick question" in the lab because many students assume provincial law applies to employees in each province—it may not if the company operates interprovincially.
NorthStream Context	NorthStream operates a fleet of transport trucks and regional pipelines across four provinces (Alberta, BC, Ontario, Quebec). This interprovincial transportation and pipeline infrastructure likely qualifies as a FWUB, meaning federal PIPEDA jurisdiction applies to all employee data, even employees working within a single province. This is advantageous because: (1) uniform federal standard (PIPEDA) rather than separate provincial standards; (2) no need to apply PIPA (BC/Alberta)

Field	Detail
	separately; (3) Quebec employees still subject to Law 25, but employment data may be under federal PIPEDA. This requires legal confirmation via corporate counsel, but the indication is strong that NorthStream operates under federal jurisdiction for employment matters.
Compliance Action	(1) Obtain legal opinion from corporate counsel on FWUB classification; (2) If federal jurisdiction confirmed, document this determination and apply PIPEDA uniformly to all employee data; (3) Maintain separate compliance file on FWUB determination for regulatory defense; (4) Align HR data practices with federal PIPEDA standards (consent, safeguards, access, correction rights).
Risk Assessment	Misclassification Risk: If NorthStream assumes provincial law applies (e.g., PIPA for Alberta employees, Law 25 for Quebec employees) but actually operates under federal PIPEDA, the company may apply suboptimal or inconsistent standards. Conversely, if federal jurisdiction is not established, applying federal PIPEDA to all employees may leave gaps in provincial compliance. Recommended: Obtain legal determination as part of compliance framework.

LEG-06: THIRD-PARTY VENDOR DATA PROCESSING AGREEMENTS (MARKETING VENDOR)

Field	Detail
ID	LEG-06
Data Subject	Marketing Database (50,000 email addresses); vendor is third-party processor
Jurisdiction	Canada (recipient jurisdiction) + USA (vendor location)
Applicable Legislation	PIPEDA Principle 4.9 (Third-Party Management); CASL Section 13 (Outsourced Compliance); Quebec Law 25 Articles 55–57 (Data Processing Agreements)

Field	Detail
Specific Requirement	Organizations that engage third parties to process personal information remain accountable for compliance. PIPEDA does not permit organizations to delegate legal responsibility to vendors. Key requirements: (1) Written Data Processing Agreement specifying: (a) purpose and scope of processing; (b) security measures; (c) confidentiality obligations; (d) restrictions on sub-processing; (e) right to audit; (f) data return/destruction upon contract end; (2) Due diligence on vendor: verify vendor's security practices, location of data storage, and compliance certifications; (3) Liability allocation: contract must specify liability for breaches (who pays penalties?); (4) Cross-border transfer rules: if vendor stores data in USA, ensure contractual safeguards and document the legitimacy of transfer (Canadian law permits transfer with appropriate safeguards; US has weaker privacy law). Quebec Law 25 raises the bar: mandatory written data processing agreements, vendor audit rights, and explicit vendor liability clauses.
NorthStream Context	NorthStream's marketing database (50,000 email addresses) is managed by a third-party vendor in the USA. This creates several compliance obligations: (1) PIPEDA accountability: NorthStream remains responsible for CASL and PIPEDA compliance even though vendor executes campaigns; (2) Vendor contract deficiency: if NorthStream's contract with the vendor does not include CASL compliance clauses (e.g., "vendor certifies email list was built with express consent") and data processing terms, NorthStream is non-compliant; (3) Cross-border transfer: marketing email addresses are PII. If vendor stores them in US data centers without explicit safeguards, this may violate Canadian privacy principles (though US storage alone is not per se non-compliant; depends on contract terms); (4) CASL enforcement: CRTC views the contracting Canadian organization as responsible for CASL compliance; vendor's location does not exempt Canadian organization from liability.
Compliance Action	(1) Audit vendor contract immediately: obtain signed data processing agreement specifying: (a) CASL compliance obligations; (b) data location; (c) security standards; (d) audit rights; (e) liability allocation; (2) If vendor contract is deficient, amend it to include: (a) written certification that email list was built with express, documented consent; (b) commitment to send emails only as instructed (per NorthStream's consent records); (c) immediate response to unsubscribe requests (within 10 days); (d) security standards (e.g., encryption in transit, access

Field	Detail
	controls); (3) Obtain Security Attestation or SOC2 report from vendor verifying security practices; (4) For Quebec customers, ensure vendor acknowledges Law 25 data processing terms; (5) Document vendor due diligence in compliance file.
Risk Assessment	Non-compliance Penalty: CASL: up to 1,000,000 CAD in fines (NorthStream liable even if vendor fails to comply). Business Impact: If vendor sends non-CASL-compliant emails, NorthStream faces regulatory action despite vendor's negligence. Recommend: obtain vendor assurance before sending any promotional emails.

PART 3: COMPLIANCE STRATEGY & CONFLICT OF LAWS RESOLUTION

Strategic Decision: Jurisdictional Approach

NorthStream faces a Conflict of Laws problem: different provinces impose different privacy standards. The company has two strategic options:

Option 1: Jurisdictional Segregation (Decentralized)

Approach: Apply law of each province independently to residents thereof.

Province	Law	Application
Alberta	PIPA + PIPEDA	Apply provincial PIPA for Alberta residents' data
BC	PIPA + PIPEDA	Apply provincial PIPA for BC residents' data
Ontario	PIPEDA only (no provincial equivalent)	Apply federal PIPEDA
Quebec	Quebec Law 25 + PIPEDA	Apply Law 25 for Quebec residents; Law 25 is stricter, supersedes PIPEDA

Advantages:

-  Locally compliant (meets each province's specific floor)
-  Demonstrates good-faith jurisdictional awareness

Disadvantages:

-  Operationally complex: different privacy policies per province
-  Different employee data handling by province
-  Different consent forms, opt-in mechanisms, breach notification timelines
-  Higher IT/legal costs to maintain segregated systems and policies
-  Greater audit burden and likelihood of error
-  Difficult to scale as organization grows (add provinces = add complexity)

****Option 2: Strictest Law Standard (Centralized) ← RECOMMENDED**

Approach: Apply Quebec Law 25 (the strictest Canadian privacy standard) to all Canadian operations, regardless of province. This ensures that all customers, employees, and third parties benefit from the highest privacy protection.

Province	Data Handling	Law Applied
Alberta	All data per Quebec Law 25	Quebec Law 25 baseline
BC	All data per Quebec Law 25	Quebec Law 25 baseline
Ontario	All data per Quebec Law 25	Quebec Law 25 baseline
Quebec	All data per Quebec Law 25	Quebec Law 25 (native)

Advantages:

-  Single compliance framework: one privacy policy, one consent form, one breach notification timeline
-  Operational simplicity: unified IT systems, staff training, audit procedures
-  Risk reduction: exceeding minimum standards provides regulatory buffer
-  Future-proofed: if other provinces adopt stricter laws (e.g., Ontario considering Law 25-like update), no process changes required
-  Scalability: adding new provinces or regions requires no compliance rework
-  Transparency benefit: customers see highest privacy standard, improving trust and brand reputation
-  Vendor contracts: all vendors given single standard, no per-province variation

Disadvantages:

-  Higher initial compliance cost (appointing Privacy Officer, conducting PIAs)
-  Slightly more burdensome than minimum PIPEDA (but manageable for mid-sized organization)

NorthStream Compliance Recommendation

Adopt Option 2: Implement Quebec Law 25 as organization-wide baseline.

Rationale:

1. Quebec Law 25 is the Canadian gold standard. It includes mandatory Privacy Officer, Privacy Impact Assessment requirements, and 24-hour breach notification—all best practices that exceed other provinces. Adopting Law 25 organization-wide positions NorthStream as privacy-forward and defensible in any regulatory inquiry.
2. Montreal Cloud Infrastructure Trigger. Because NorthStream's Rewards Cloud is hosted in Montreal, Law 25 is already mandatory for that system. Applying Law 25 to all Canadian operations eliminates the complexity of "different rules for different data" and reduces the chance of data flowing to the wrong province-specific processing pipeline.
3. Operational Simplicity Outweighs Marginal Cost. While appointing a Privacy Officer and conducting PIAs involve upfront cost (~15,000–25,000 CAD), the ongoing operational simplicity—unified privacy policy, single consent form, uniform vendor contracts—saves

money over 3–5 years by reducing audit, legal, and IT overhead. For a mid-sized organization like NorthStream, this is highly justified.

4. **Vendor & Employee Clarity.** All third parties (cloud provider, marketing vendor, HR consultants) are given a single, clear standard. No confusion about "which law applies to this data?" reduces contracting risk and vendor errors.
5. **Regulatory Relationship.** Demonstrating proactive adoption of Quebec Law 25 organization-wide signals to regulators (CRTC for CASL, CAI for Law 25, OPC for PIPEDA) that NorthStream is compliance-conscious, reducing likelihood of aggressive enforcement.

Implementation Roadmap (12 months)

Phase	Timeline	Action	Owner	Cost Estimate
1: Foundation	Months 1–2	Appoint Privacy Officer (external consultant); obtain FWUB legal opinion	Legal/HR	10,000 CAD
2: Assessment	Months 2–3	Conduct Privacy Impact Assessment for Rewards App; audit vendor contracts	Privacy Officer	12,000 CAD
3: Policy	Months 3–4	Draft unified privacy policy, consent forms, breach notification procedure	Legal/Privacy Officer	8,000 CAD
4: Technical	Months 4–6	Implement consent tracking system; encrypt employee data; audit firewalls	IT/Security	20,000 CAD
5: Third-Party	Months 6–7	Amend vendor contracts (marketing, cloud provider); obtain vendor attestations	Procurement/Legal	5,000 CAD

Phase	Timeline	Action	Owner	Cost Estimate
6: Training	Months 7–8	Mandatory privacy compliance training for all staff	HR	3,000 CAD
7: Documentation	Months 8–9	Maintain compliance register, audit logs, PIA file	Privacy Officer	2,000 CAD
8: Testing	Months 9–10	Tabletop breach response exercise; vendor audit	Privacy Officer/Security	5,000 CAD
9: Launch	Months 10–12	Deploy unified privacy framework; notify customers of policy updates	Marketing/Privacy Officer	3,000 CAD
Total Estimated Cost				68,000 CAD

REFERENCES

Federal Legislation & Resources

- Office of the Privacy Commissioner of Canada (OPC)
<https://www.priv.gc.ca/en/>
 - PIPEDA guidance, complaint procedures, enforcement actions
- Personal Information Protection and Electronic Documents Act (PIPEDA)
<https://www.justice.gc.ca/eng/csj-sjc/pl/pipeda-lprpde/index.html>
 - Text of federal law; Part 1 (private sector), Part 2 (federal institutions)
- CASL (Canada's Anti-Spam Legislation)
<https://ised-isde.canada.ca/site/canada-anti-spam-legislation/en>
 - CASL guidance, exemptions, enforcement by CRTC

4. Canadian Radio-television and Telecommunications Commission (CRTC) – CASL Enforcement

<https://www.crtc.gc.ca/eng/enforcement/spam.htm>

- CASL enforcement statistics, settlement agreements
-

Quebec Legislation & Resources

5. Commission d'accès à l'information du Québec (CAI)

<https://www.cai.gouv.qc.ca/>

- Quebec privacy regulator; Law 25 guidance

6. LegisQuébec – Law 25 (Loi modernisant les dispositions législatives en matière de protection des renseignements personnels)

<https://www.legisquebec.gouv.qc.ca/en/document/cs/p-39.1>

- Full text of Quebec privacy law (effective 2023)

7. CAI Guidance on Privacy Impact Assessments (French: "Évaluation des risques relatifs à la vie privée")

<https://www.cai.gouv.qc.ca/publication/privacy-impact-assessment/>

- PIA requirements under Law 25
-

Provincial Legislation (BC & Alberta)

8. Personal Information Protection Act (PIPA) – British Columbia

https://www.bclaws.gov.bc.ca/civix/document/id/complete/statreg/00003063_01

- BC private sector privacy law (substantially similar to PIPEDA)

9. Personal Information Protection Act (PIPA) – Alberta

<https://www.canlii.org/en/ab/laws/stat/rsa-2000-c-p-6-5/latest/rsa-2000-c-p-6-5.html>

- Alberta private sector privacy law
-

Federal Jurisdiction & FWUB Precedents

10. Supreme Court of Canada: *R. v. Kitkatla Band*, [2002] 2 S.C.R. 146

<https://scc-csc.lexisnexis.com/scc-csc/scc-csc/en/item/2000/index.do>

- Landmark case on federal jurisdiction over FWUB; constitutional interpretation

11. Government of Canada – Federal Works, Undertakings, and Businesses

https://www.justice.gc.ca/eng/csj-sjc/pl/pipeda-lprpde/art_4.html

- PIPEDA Part 2 scope; definition of federal jurisdiction

NIST & Industry Frameworks (Future Reference)

12. NIST Cybersecurity Framework (CSF)

<https://www.nist.gov/cyberframework>

- Framework for aligning privacy/security controls (relevant for future mapping tasks)

13. Center for Internet Security (CIS) Benchmarks

<https://www.cisecurity.org/cis-benchmarks>

- Technical security standards (relevant for implementation planning)